

Cyber Incident Response Plan

SLOVPACK s.r.o. · Operational plan under the Incident Management Policy (SLP-POL-005)

Field	Value
Document ID	SLP-ISMS-016
Version	1.0
Classification	Internal
Owner	ISMS Manager
Plan Owner / Incident Lead	Marek Urban, IT Administrator
Approved by	Peter Kováč, Managing Director
Effective date	01 July 2026
Review cycle	Annually, or after any Major/Critical incident
Parent document	SLP-POL-005 Incident Management Policy
Related documents	SLP-ISMS-003 Information Security Policy; SLP-ISMS-004 ISMS Roles and Responsibilities; SLP-ISMS-007 Risk Register (RSK-001, RSK-002, RSK-009, RSK-016); SLP-ISMS-009 Statement of Applicability (A.5.24-A.5.28, A.6.8, A.8.2); SLP-ISMS-013 Corrective Action Register; SLP-POL-001 Acceptable Use Policy; SLP-POL-004 Backup Policy; SLP-POL-006 Supplier Security Policy

Version history

Version	Date	Author	Change
1.0	01 July 2026	M. Urban / ISMS Manager	Initial issue. Approved by the Managing Director.

DISCLAIMER: SLOVPACK s.r.o. is a fictional company created for portfolio purposes. All company data, personal names, employee and supplier contact details and scenarios are invented. Contact details for national authorities (Data Protection Authority, SK-CERT) are shown as they exist publicly, for realism only.

1. Purpose

This plan defines how SLOVPACK s.r.o. prepares for, detects, responds to, and recovers from cyber security incidents. It operationalises the Incident Management Policy (SLP-POL-005), which requires a documented response capability, defined roles, and compliance with contractual and legal notification obligations.

The plan is written for the reality of SLOVPACK: a 45-employee packaging manufacturer with a single internal IT administrator, supported by a managed service provider (NetAdmin Solutions). It deliberately avoids procedures that require capabilities SLOVPACK does not have.

2. Scope

This plan covers all information systems, services, and data owned or operated by SLOVPACK s.r.o. at the Bratislava headquarters and the Senec warehouse, including systems administered by NetAdmin Solutions on SLOVPACK's behalf. It covers incidents affecting confidentiality, integrity, or availability of information, including but not limited to: phishing and account compromise, malware and ransomware, data breaches, loss or theft of devices, and misuse of privileged access (internal or by the MSP).

Physical safety incidents and general IT service faults without a security dimension are out of scope and are handled through standard IT support.

3. Definitions

- Security event — an observable occurrence with potential security relevance (e.g., a reported suspicious email, a failed login spike).
- Security incident — an event with confirmed impact on the confidentiality, integrity, or availability of SLOVPACK information or systems (per SLP-POL-005).
- Personal data breach — an incident leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data (GDPR Art. 4(12)).

The IT Administrator decides whether an event is classified as an incident. In his absence, the ISMS Manager decides; escalation follows the path defined in SLP-POL-005: IT Administrator → ISMS Manager → Managing Director.

4. Incident Response Team (IRT)

SLOVPACK does not maintain a dedicated security team. The IRT is a virtual team activated when an incident is declared.

Role	Person	Responsibilities
Incident Lead	Marek Urban (IT Administrator)	Triage, classification, technical response coordination, evidence preservation, incident log
ISMS oversight	ISMS Manager (per SLP-ISMS-004)	Document owner, backup reporting contact, escalation point between IT Administrator and Managing Director, incident oversight, lessons-learned facilitation, policy owner (SLP-POL-005)
Decision Authority	Peter Kováč (Managing Director)	Declares Major/Critical incidents, approves system shutdowns, ransom decisions, external notifications, and spending
Data Protection & HR Liaison	Jana Šimková (Finance & HR)	GDPR breach assessment support, communication with the Data Protection Authority, HR aspects (insider incidents), payment fraud response
Customer Communications	Katarína Bielíková (Sales)	Notifications to customers, primarily PharmaVital (24-hour contractual obligation)
Warehouse Operations	Ľubomír Hruška (Warehouse Manager)	Impact assessment and manual fallback procedures for warehouse and dispatch operations in Senec
Technical Support (external)	NetAdmin Solutions (MSP)	Network/server forensic support, restoration from backup, after-hours first response per support contract

Deputy rule: If Marek Urban is unavailable, NetAdmin Solutions acts as Incident Lead for technical matters and Peter Kováč assumes coordination. Every IRT member has a named deputy recorded in Appendix A. This addresses the single-administrator dependency recorded as RSK-011.

5. Severity Classification

Severity	Definition	Examples	Response target	Who is activated
SEV-1 Critical	Business-stopping impact, confirmed data breach, or safety/legal exposure	Ransomware encrypting production or file servers; confirmed exfiltration of customer or personal data	Immediate; IRT convenes within 1 hour	Full IRT + MSP; Managing Director always
SEV-2 Major	Significant impact on one site, department, or key customer; probable data exposure	Compromised M365 account of Finance; malware on multiple PCs; MSP access misuse suspected	Response within 4 business hours	Incident Lead + Managing Director + affected function
SEV-3 Minor	Contained, low impact, no data exposure	Single phishing email reported and deleted; malware blocked by endpoint protection; lost phone with confirmed remote wipe	Within 1 business day	Incident Lead only; logged and reviewed

Severity is assigned at declaration and reassessed as facts emerge. Escalation upward requires no approval; de-escalation requires the Managing Director's agreement for SEV-1/SEV-2.

6. Incident Response Lifecycle

The plan follows the NIST SP 800-61 lifecycle, scaled to SLOVPACK.

6.1 Preparation (ongoing)

- Maintain this plan, the contact list (Appendix A), and the incident report form (Appendix B).
- Maintain offline copies of this plan at both sites (printed, in the IT cabinet in Bratislava and the warehouse office in Senec) — a ransomware incident may make the digital copy unavailable.
- Quarterly backup restore tests are performed by NetAdmin Solutions with a written report reviewed by the ISMS Manager (per SLP-POL-004); the IT Administrator additionally verifies backup job completion monthly.
- Annual security awareness refresher for all staff, including "how to report an incident" (see 6.2), delivered under the Awareness and Training Plan (SLP-ISMS-014).
- One tabletop exercise per year (see Section 11).

Known limitation (RSK-016). SLOVPACK does not operate centralised logging or 24/7 monitoring. The RSK-016 treatment (target 30 June 2026) introduces a minimal monitoring and evidence-collection runbook; until it is fully operational, detection relies primarily on user reports, endpoint protection alerts, periodic M365 audit log review, and MSP notifications. Log coverage before mid-2026 is limited or absent, and investigations into earlier activity must account for the possibility that historical evidence is unavailable. This limitation is stated deliberately: response decisions must be made in the knowledge that root cause may not be determinable.

6.2 Detection and Reporting

Per SLP-POL-005, any employee who observes a security event must report it within 1 hour of detection to the IT Administrator (backup contact: ISMS Manager):

- In person or by phone (preferred for anything urgent)
- Email: incident@slovpack.sk (monitored by the IT Administrator)
- Out of hours: phone the IT Administrator; if unreachable, the ISMS Manager, then the NetAdmin Solutions 24/7 line

Rules for reporters:

1. Do not switch off the affected computer (memory evidence may be lost) — disconnect the network cable or Wi-Fi instead, if instructed.
2. Do not forward suspicious emails to colleagues; report them.
3. Do not attempt to "fix" or investigate on your own.
4. Reporting a suspected incident, including one caused by your own mistake, will never be penalised. Late reporting or concealment will be.

6.3 Triage and Analysis

Performed by the Incident Lead, with MSP support for server/network matters:

1. Record the report in the Incident Log (Appendix C) — date/time, reporter, affected system, initial description.
2. Confirm whether the event is an incident (Section 3) and assign severity (Section 5).
3. Establish initial scope: which accounts, devices, data, and sites are affected; whether personal data or PharmaVital-related data is involved (this triggers the notification clock — Section 7).
4. For SEV-1/SEV-2: open a dedicated incident record, start a timeline, and inform the Managing Director immediately.
5. Preserve evidence before remediation wherever feasible (Section 9).

6.4 Containment

Priority: stop the spread, protect backups, keep the business running where safely possible.

Standard containment actions (pre-approved, no additional authorisation needed):

- Disconnect affected endpoints from the network (physically or via Wi-Fi/switch port with MSP help).
- Disable or reset compromised user accounts; revoke active sessions in Microsoft 365.
- Block malicious senders, domains, and URLs at the mail filter and firewall.
- Isolate the Senec warehouse network segment from Bratislava if either site is compromised.

Actions requiring Managing Director approval:

- Shutting down the file server, ERP/invoicing system, or e-mail for all users.
- Suspending NetAdmin Solutions' remote access (RSK-009 scenario — see Playbook C).
- Any external communication about the incident.

Backups must be verified as isolated and undamaged before any eradication step in every SEV-1 incident.

6.5 Eradication and Recovery

- Remove malware, close the exploited entry point (e.g., reset credentials, patch, reconfigure), and confirm with the MSP that persistence mechanisms have been checked on affected systems.
- Restore systems from the most recent clean backup; the IT Administrator confirms restore point selection with the MSP and the affected business owner.
- Reset passwords for all affected accounts; for SEV-1 incidents, a company-wide password reset is the default unless the Incident Lead documents why it is unnecessary.
- Return to normal operations only after the Incident Lead confirms systems are clean and the Managing Director approves resumption (SEV-1/SEV-2).
- Warehouse fallback: dispatch and goods receipt in Senec can run on paper forms for up to 3 business days (owner: Ľubomír Hruška); data is back-entered after recovery.

6.6 Post-Incident Activity

Within 10 business days of closing a SEV-1 or SEV-2 incident:

- The Incident Lead completes the final incident report (Appendix B) including timeline, root cause, impact, and actions taken.
- A lessons-learned meeting is held with the IRT members involved.
- Corrective actions are entered into the Corrective Action Register (SLP-ISMS-013) with owners and due dates.

- The Risk Register is reviewed: does the incident change the likelihood or impact of any recorded risk, or reveal a new one?
- SEV-3 incidents are reviewed in aggregate at the annual management review.

7. Notification and Escalation Obligations

Time obligations run from awareness of the qualifying facts, not from completion of the investigation. When in doubt, notify early with preliminary information and follow up.

Recipient	Trigger	Deadline	Channel	Responsible
Managing Director	Any SEV-1 or SEV-2 declaration	Immediately	Phone	Incident Lead
PharmaVital a.s.	Any incident affecting, or reasonably likely to affect, PharmaVital data, orders, or supplied packaging (per Quality & Security Agreement)	24 hours from awareness	Email to PharmaVital security contact + phone confirmation	Katarína Bieliková, content approved by Managing Director
Data Protection Authority (Úrad na ochranu osobných údajov SR)	Personal data breach likely to result in a risk to individuals (GDPR Art. 33)	72 hours from awareness	Official notification form	Jana Šimková, with Incident Lead input
Affected data subjects	Breach likely to result in a high risk to individuals (GDPR Art. 34)	Without undue delay	Email/letter, template pre-approved	Jana Šimková
Police of the Slovak Republic	Suspected criminal activity (fraud, extortion, insider theft)	As decided	Report to local police / cybercrime reporting	Managing Director
SK-CERT	Significant cyber incident (voluntary for SLOVPACK; not currently an NIS2 essential/important entity)	Voluntary	National CSIRT reporting channel	Incident Lead
Bank	Suspected payment fraud / fraudulent transaction	Immediately	Bank fraud hotline	Jana Šimková
Cyber insurance provider	Any SEV-1 incident — applies only if cyber cover is in place; cover is currently under consideration (SLP-ISMS-001)	Per policy (typically 48 hours)	Broker contact in Appendix A	Managing Director

GDPR breach assessment: Jana Šimková and the Incident Lead jointly complete the breach assessment section of the incident form (data categories, subjects affected, likely consequences, mitigations). If the conclusion is "no risk to individuals," the reasoning is documented and retained — GDPR requires internal records of all personal data breaches regardless of whether they are notified.

8. Communications During an Incident

- Out-of-band channel: if email or the corporate network may be compromised, the IRT communicates by phone and by a pre-agreed encrypted messaging group. Use of this channel by IRT members is a documented exception to the Acceptable Use Policy (SLP-POL-001 §5), approved by the ISMS Manager and limited to incident response. Incident details are never discussed over potentially compromised systems.
- Only the Managing Director, or Katarína Bieliková with his approval, communicates externally (customers, media, partners). All other employees refer inquiries to them.
- Internal staff updates during SEV-1 incidents are issued by the Managing Director at least once per business day, even if the update is "investigation continues."
- Speculation about causes or perpetrators is prohibited in all written communication until the investigation concludes.

9. Evidence Handling

Scaled to SLOVPACK's capabilities:

- Preserve before you clean: photograph on-screen messages (including ransom notes), export relevant emails with full headers, note exact times and system clocks.
- Do not power off affected machines unless spread cannot be contained otherwise; disconnect from the network instead.
- The MSP creates disk images of critical affected systems before reinstallation in SEV-1 incidents; images are stored on dedicated external media held by the IT Administrator.
- Maintain a simple chain-of-custody note for any preserved media: what, when, who took it, where stored.
- All evidence is retained for a minimum of 24 months or until legal/insurance matters close, whichever is later.
- If law enforcement or insurers become involved, no evidence is deleted and no systems are reinstalled without their confirmation.

10. Scenario Playbooks

Playbook A — Phishing / Account Compromise (RSK-001)

Trigger: a user reports a suspicious email, a clicked link, entered credentials, or unusual account activity (unexpected sent items, inbox rules, MFA prompts).

1. The reporter forwards nothing; the Incident Lead retrieves the email directly from the mailbox.
2. If credentials were entered or compromise is suspected: immediately reset the account password and revoke all active sessions in Microsoft 365; verify that MFA methods registered on the account have not been altered.
3. Check the mailbox for attacker artefacts: new inbox rules (especially forwarding or deletion rules), changed recovery details, sent items.
4. Search for and purge the same phishing email from all other mailboxes; block the sender and URL at the mail filter.
5. Ask all staff via the internal channel whether they received or clicked the same message (short, factual notice).
6. Assess data exposure: what could be accessed from the compromised mailbox (customer data? personal data? PharmaVital correspondence?). This drives the Section 7 notifications.
7. Finance-specific rule: if the compromised account belongs to Finance, or the phishing relates to invoices or payments, Jana Šimková immediately verifies recent and pending payment instructions by phone with counterparties, and the bank is contacted about any suspicious transaction.
8. Severity: single reported email with no click = SEV-3. Credential entry or evidence of access = SEV-2 minimum; confirmed data access = evaluate for SEV-1.

Playbook B — Ransomware (RSK-002)

Trigger: encrypted files, a ransom note, systems inaccessible, or endpoint protection alerts on encryption behaviour.

1. Immediately disconnect affected devices from the network. If spread is ongoing or scope is unknown, the Incident Lead is pre-authorised to disconnect the Bratislava-Senec site link and take the file server off the network; full shutdown of servers requires Managing Director approval.
2. Call the NetAdmin Solutions 24/7 line; declare SEV-1; convene the IRT within 1 hour.
3. Verify backups first: the MSP confirms backup integrity and isolates backup storage from the network before anything else. Per RSK-002, the backup NAS (AST-011) is network-connected and may itself be encrypted — the immutable cloud backup tier (SLP-POL-004, 3-2-1 rule) is the primary recovery fallback and its integrity must be verified first. Backups are the recovery path — protecting them outranks investigation speed.
4. Photograph the ransom note; do not delete it. Identify the strain if possible (note the file extension and ransom note text) and check publicly available decryptor resources.
5. Establish scope with the MSP: which systems, one site or both, whether the domain controller is affected, and any signs of data exfiltration. Many modern ransomware operations steal data before encrypting — assume exfiltration until disproven; this triggers the GDPR and PharmaVital assessment per Section 7.
6. Ransom payment position: SLOVPACK's default position is not to pay. Any deviation is decided solely by the Managing Director after consulting the insurer, legal counsel, and police, and is documented.
7. Warehouse continuity: Lubomír Hruška activates paper-based dispatch and goods receipt; Katarína Bielíková informs affected customers of possible delays (PharmaVital within 24 hours if their orders are affected).
8. Recovery: rebuild affected systems from clean media, restore data from verified backups, perform a company-wide password reset (including MSP-held privileged accounts), and re-admit systems to the network in stages.
9. Post-incident: mandatory review of the initial access vector and a corresponding Risk Register update. This scenario is the primary argument for closing RSK-016 — without logs, determining the entry point may be impossible, which must be stated honestly in the report rather than replaced with a guess.

Playbook C — MSP Privileged Access Concern (RSK-009)

Trigger: unexplained administrative changes, MSP-attributed activity outside agreed maintenance windows, notification of a security breach at NetAdmin Solutions, or suspicion of misuse of MSP credentials by a third party.

1. The Incident Lead informs the Managing Director before contacting the MSP if misuse by the MSP is suspected; if the MSP itself reports being breached, proceed cooperatively.
2. With Managing Director approval, suspend the MSP's remote access accounts and VPN until the situation is clarified. SLOVPACK holds break-glass local administrator credentials (sealed envelope, company safe, checked quarterly) precisely for this scenario. This control supports A.8.2 (privileged access rights) and is maintained under the RSK-009 treatment.
3. Request from the MSP: a written account of the activity in question, a list of accounts and systems accessed, and their own incident findings if they were breached. Per SLP-POL-006 and the RSK-009 contract addendum, NetAdmin Solutions is contractually obliged to notify SLOVPACK of security incidents on their side within 24 hours — failure to do so is itself a

contractual breach and is recorded in the incident report.

4. Review whatever access records exist on SLOVPACK systems (VPN logs, server event logs, M365 sign-in logs) — acknowledging the RSK-016 limits described in 6.1.
5. Reset all privileged credentials known to the MSP once the immediate response concludes, regardless of outcome.
6. Assess contractual and notification consequences: does the activity constitute a data breach (Section 7)? Does the MSP contract's security clause apply?
7. Post-incident: review MSP access scope against least privilege and feed findings into the annual supplier assessment required by SLP-POL-006.

11. Testing and Maintenance

- Annual tabletop exercise: one scenario per year (rotating: ransomware, phishing/BEC, MSP compromise), led by the IT Administrator and attended by all IRT members. Findings are recorded and tracked as corrective actions in SLP-ISMS-013.
- The contact list (Appendix A) is verified quarterly by the IT Administrator.
- Break-glass credentials are checked quarterly (envelope integrity, password validity).
- The plan is reviewed annually, after every SEV-1/SEV-2 incident, after any material change (new key customer, new system, MSP change), and after each tabletop exercise.
- Version history and approvals are maintained in the document control tables on page 1.

12. Plan Approval

This plan is approved under the authority of the Incident Management Policy (SLP-POL-005).

Name	Role	Signature	Date
Peter Kováč	Managing Director	signed	01 July 2026
Marek Urban	IT Administrator (Plan Owner / Incident Lead)	signed	01 July 2026
ISMS Manager	Document Owner	signed	01 July 2026

Appendix A — IRT Contact List

All company and personal contact details below are fictional. National authority contacts are shown for realism.

Role	Name	Phone	Email	Deputy
Incident Lead / IT Admin	Marek Urban	+421 903 214 657	m.urban@slovpack.sk	NetAdmin Solutions
Managing Director	Peter Kováč	+421 905 118 320	p.kovac@slovpack.sk	Jana Šimková
Finance/HR & DPO Liaison	Jana Šimková	+421 907 442 815	j.simkova@slovpack.sk	Peter Kováč
Customer Communications	Katarína Bieliková	+421 911 736 204	k.bielikova@slovpack.sk	Peter Kováč
Warehouse Manager (Senec)	Ľubomír Hruška	+421 908 561 493	l.hruska@slovpack.sk	Shift leader on duty
MSP 24/7 hotline	NetAdmin Solutions	+421 2 5443 8800	soc@netadminsolutions.sk	—
PharmaVital security contact	(per Quality & Security Agreement)	+421 2 6820 1150	security@pharmavital.sk	—
Data Protection Authority SR	—	see authority website	official notification form	—
SK-CERT	—	see authority website	national CSIRT channel	—
Cyber insurance broker	InsurTech Broker s.r.o.	+421 902 655 010	claims@insurtechbroker.sk	—

Appendix B — Incident Report Form (structure)

1. Incident ID (INC-YYYY-NNN) and severity
2. Reported by / date and time of report / date and time of awareness
3. Description and affected systems, sites, accounts, data
4. Timeline of events and response actions (chronological)
5. Personal data breach assessment (categories, subjects, risk conclusion, notification decision and reasoning)
6. PharmaVital impact assessment and notification record
7. Root cause — or a documented statement that root cause could not be determined, and why

8. Business impact (downtime, cost, data)
9. Corrective actions raised, with Corrective Action Register (SLP-ISMS-013) references
10. Closed by / date / Managing Director sign-off (SEV-1/SEV-2)

Appendix C — Incident Log

Register of all reported security events and incidents. Maintained by the IT Administrator and reviewed at the annual management review.

ID	Date	Reporter	Summary	Severity	Status	Report ref.
----	------	----------	---------	----------	--------	-------------

No incidents have been recorded since plan adoption. Entries are added on declaration and closed following the process in Section 6.6.